

AGRIAI 2.0

INTELLIGENT FARMING ASSISTANT FOR GHANA

Volume V. Security Threat Model

What is already locked, what can still bite, and how to operate safely

Prepared and authored solely by Thaddeus Nii Teiko Tagoe

Computer Science, University of Ghana

Founder, designer, and sole engineer of AgriAI

Repository: ThaddeusHackz/agriai-v2

Document date: 18 August 2026

Classification: Internal forensic architecture pack

This document explains how AgriAI was built, which source files make the AI work, and how the public and admin APIs stay reliable when a provider is missing. Every claim below is taken from the live codebase, not from marketing copy.

1. Scope

This volume is an honest forensic review of AgriAI 2.0 as it exists in ThaddeusHackz/agriai-v2. It is not a penetration test against a live host. It reads lib/auth.ts, next.config.ts, route validators, env handling, and the data store, then names real risks a Ghana deployment will meet.

2. Trust boundaries

- Browser (farmer or attacker) may only call AgriAI HTTP routes. Vendor keys never ship in NEXT_PUBLIC_* except site URL.
- Next.js Node runtime holds GEMINI, Cloudflare, Tavily, OpenWeather, ElevenLabs, Unsplash, DATABASE_URL, and admin seed secrets.
- Google, Cloudflare, Tavily, OpenWeather, and ElevenLabs are third parties. AgriAI must treat their output as untrusted text.
- Admin cookie agriai_session is the only proof of staff identity. Role is admin or editor.
- data/db.json and PostgreSQL agriai_state hold chats, hashes, sessions, prices, and subscribers. Disk and DB are the crown jewels.

3. Controls that already work

- Passwords hashed with bcryptjs cost 10. publicUser() strips passwordHash from JSON.
- Session token is 32 random bytes hex. Cookie is httpOnly, sameSite lax, secure in production, path /.
- Remember me: 7 day maxAge. Without remember: 8 hours. Expired sessions pruned on login.
- Login rate limit: 5 failures per IP per 15 minutes, HTTP 429. Failed login does not reveal whether the email exists.
- Chat message clipped to 2000 chars. History clipped. Language and mode whitelisted.
- Vision body cap about 4.5 MB. Transcribe audio cap 25 MB. TTS text cap 1500 chars.
- Studio SAFE_SUBJECTS block turns the image API away from general abuse.
- lib/env.ts strips quotes, rejects YOUR_ and CHANGE_ME placeholders, never logs secret values.
- next.config.ts sets X-Content-Type-Options nosniff and Referrer-Policy strict-origin-when-cross-origin.
- GET /api/health reports provider configured/live flags without dumping keys.
- Reset and user CRUD sit behind getSessionUser.

4. Threat catalog

4.1 Prompt injection and jailbreak of AgriAI

A farmer (or a script) can put instructions in the message or in a pasted web page that Tavily later injects into the system block. The model may ignore Ghana agronomy rules, invent pesticide doses, or echo hidden text from a source. Mitigation already present: citation markers, short maxTokens, temperature from admin. Residual risk: high for advice quality, medium for brand. Operator action: keep expert mode for trained staff, and treat every chemical rate as something a MoFA officer must confirm.

4.2 Cost abuse and denial of wallet

POST /api/chat, /api/vision, /api/generate, /api/transcribe, and /api/tts have no farmer login and no per IP quota. An open Render URL can be scripted until Gemini, Flux, or ElevenLabs bills spike. Chat also writes every turn to disk. Mitigation: 60s maxDuration and payload caps. Residual risk: high on a public hostname. Operator action: put a reverse proxy rate limit, Cloudflare WAF, or a simple token in front of AI routes before a national launch.

4.3 Admin session theft

sameSite lax blocks most CSRF cookie sends from evil sites on POST in modern browsers, but XSS on the AgriAI origin would still read nothing (httpOnly) while still being able to call /api/admin/* as the victim. There is no CSRF token pair. Session lives in the JSON document, so a stolen db.json is a stolen session list. Residual risk: medium. Operator action: HTTPS only, short remember windows, rotate admin passwords after any disk leak, add Content-Security-Policy when the UI is stable.

4.4 Default and seed credentials

defaultDB() seeds ADMIN_EMAIL or admin@agriai.gh and ADMIN_PASSWORD or AgriAI@2026Admin. If env is forgotten on first boot, that well known password is in bcrypt form on disk. README already says change it in Admin Users. Residual risk: critical on any public demo that skipped env. Operator action: set a long ADMIN_PASSWORD before the first process start, then change it again in the panel.

4.5 Rate limit bypass

attempts is an in-memory Map keyed by x-forwarded-for first hop. On multi instance Render or if an attacker spoofs X-Forwarded-For in front of a misconfigured proxy, the 5/15 limit evaporates. Residual risk: medium. Operator action: trust only the platform hop, or move limits to the edge.

4.6 Sensitive data in the document store

Chats may contain farm locations, phone numbers, and distress. Subscribers and contacts are emails. Sessions include IP and user agent. The JSON file is gitignored, which is correct, but a backup or a world readable Render disk snapshot would expose them. Postgres mirror helps durability and also concentrates the same PII. Residual risk: high if backups are casual. Operator action: encrypt at rest on the host, restrict who can open the admin Messages tab, publish a retention rule.

4.7 SSRF and outbound fetch

Search, weather, Cloudflare, Tavily, Wikipedia, DuckDuckGo, ElevenLabs, and Unsplash use fixed vendor URLs, not farmer supplied URLs. That is good. Image generate does not fetch a farmer URL. Residual SSRF risk is low unless a future feature fetches arbitrary links for scraping.

4.8 File and vision abuse

Vision accepts a huge base64 string in JSON. Caps exist, but a flood of 4 MB posts still burns CPU and Gemini quota. There is no virus scan because the bytes go to Gemini, not to a shared disk gallery. Residual risk: medium (cost and CPU), low (malware on server).

4.9 Health probe information leak

/api/health is public and tells the world which providers are configured and whether Gemini answered OK. That helps Thaddeus debug Render. It also helps an attacker know which wallet to drain. Residual risk: low to medium. Operator action: lock health to the platform checker or strip live error strings in production.

4.10 Missing browser hardening headers

nosniff and referrer policy are set. There is no Content-Security-Policy, no Permissions-Policy, no X-Frame-Options or CSP frame-ancestors in next.config.ts. Clickjacking the admin login in an iframe is a residual risk on older browsers. Operator action: add frame-ancestors 'self' and a strict CSP once inline styles are inventoried.

5. Abuse cases tied to AI quality

- Medical or pesticide overconfidence: expert mode can state kg/ha figures that a model invented. UI should keep the demo and live disclaimer.
- Language mismatch: a Twi request can still get English if the model ignores languageInstruction. Farmer safety depends on the farmer noticing.
- Citation theater: if search fails, local mode clears sources. If search succeeds, a wrong snippet can still be cited as [1]. Citations are not proof.
- Image studio: SAFE_SUBJECTS is substring based. Creative spelling can slip past. Keep Flux account limits on.

6. Recommended hardening order (for the sole operator)

- 1. Unique ADMIN_PASSWORD in env before first boot. Change again in the panel.
- 2. HTTPS and Render secret store only. Never commit .env.local.
- 3. Edge rate limits on /api/chat, /api/vision, /api/generate, /api/tts, /api/transcribe.
- 4. Restrict /admin and /api/admin to known staff IPs if the panel is not public on purpose.
- 5. Add CSP and frame-ancestors.
- 6. Move sessions to a signed cookie or Redis so db.json theft does not clone logins.
- 7. Redact health error strings.
- 8. Write a 90 day chat retention job.

7. Forensic verdict

AgriAI was built as a product that must stay up for farmers, not as a bank. Auth, hashing, httpOnly cookies, input caps, and key isolation are real engineering by Thaddeus Tagoe. The largest remaining holes are unauthenticated AI spend, seed password discipline, in-memory rate limits, and PII sitting in one document. Close those before a ministry scale rollout.